

MOSAIC: scoring weights and presentation defence

1. Where the numbers come from

Prepared for the presentation on 6 October 2026. Applies to scoring model severity-v2. This document is black-and-white text only.

Main research reference [1]: Nusrat Zahan, Parth Kanakiya, Brian Hambleton, Shohanuzzaman Shohan and Laurie Williams. "OpenSSF Scorecard: On the Path Toward Ecosystem-Wide Automated Security Metrics." IEEE Security & Privacy, volume 21, issue 6, pages 76-88, 2023. DOI: 10.1109/MSEC.2023.3279773.

Exact location: Section II, "OpenSSF Scorecard," in the accessible author manuscript. It explicitly gives Low = 2.5, Medium = 5, High = 7.5 and Critical = 10. Table I describes the repository checks and their risk labels.

Open manuscript: <https://arxiv.org/html/2208.03412v3#S2>. **Publisher record:** <https://doi.org/10.1109/MSEC.2023.3279773>. The manuscript is an openly accessible version of the cited research; the IEEE version can require institutional access.

How MOSAIC converts the scale

Low: $2.5 \times 10 = \mathbf{25 \text{ points}}$. Medium: $5 \times 10 = \mathbf{50 \text{ points}}$. High: $7.5 \times 10 = \mathbf{75 \text{ points}}$. Critical: $10 \times 10 = \mathbf{100 \text{ points}}$.

Multiplying by ten changes the display units. It preserves the published 1:2:3:4 relative weights. The earlier 48, 20, 12, 7 and other individually chosen values have been replaced; use fresh evaluations when presenting.

What the research supports

The paper supplies the numeric severity scale and studies security-practice metrics in software ecosystems. It does not supply learned coefficients for agent requests. In the original Scorecard, higher check scores indicate better security practice and the overall result is a weighted average. MOSAIC uses a concern index where higher is worse and uses the grouping rule on page 3.

Signal classifications, grouping, and decision boundaries are **our documented adaptations**. This is a literature-based, semi-quantitative prototype. It is not a statistically calibrated probability model, an implementation of the full Scorecard tool, or evidence that the cited authors validated MOSAIC.

2. Why each signal gets its category

Rubric: Low means uncertain/non-specific evidence or a common capability. Medium means a stronger review concern involving identity, authority, transport or linkage. High means an explicit unavailable-artifact report or a concrete execution/instruction-override pattern. No current single-signal detector assigns Critical; future independently confirmed threats could use it. Every classification below remains a hypothesis to validate.

Identity and provenance

Reported missing: High, 75. An artifact cannot be used as identified if it is unavailable. Spracklen et al., USENIX Security 2025 [2], demonstrates the hallucinated-package attack surface. High is our conservative intervention priority, not a 75% attack estimate. MOSAIC receives a caller report rather than verifying a registry.

Unknown existence: Low, 25. No evidence of existence is weaker than a report of nonexistence. We preserve that distinction instead of treating unknown as a confirmed missing artifact.

Package lookalike: Medium, 50. Ohm et al., DIMVA 2020 [3], describes typosquatting in real supply-chain attacks. A similar name can also be legitimate. It deserves review, while similarity alone does not prove malware. Our name catalog and matching boundary are prototype choices.

Reported unsigned: Low, 25. Signed provenance matters in [1]. Its actual Signed-Releases check is High; our caller-supplied unsigned boolean is much weaker evidence than examining release files. The downgrade is intentional and must be described as an adaptation.

Capabilities and content

General capability: Low, 25. Network/filesystem access may be legitimate. **Secrets, shell or process spawning: Medium, 50.** These expose sensitive information or execution authority. Least-privilege guidance [6] supports scrutiny, not the exact class assignment. Use only the strongest capability class; duplicates add nothing.

Encoding/obfuscation or a credential-location marker: Low, 25. Supply-chain and detection studies [3,4] motivate inspecting code. However, encoding and process.env occur in benign programs. These literal markers are weak evidence and do not establish exfiltration.

Remote download piped to shell: High, 75. It can execute unreviewed remote code, a mechanism relevant to [3]. Legitimate installers can also use it. **Instruction override in skill/MCP text: High, 75.** Indirect-injection research at ACM AISec 2023 [5] supports treating instruction-bearing content carefully. A regex match is not proof that an attack succeeded.

3. Remaining signals and the calculation

URL and session context

Non-HTTPS: Medium, 50. CWE-319 [8] motivates concern about transport protection. **Private/local destination: Medium, 50.** SSRF prevention guidance [7] identifies network trust boundaries; legitimate internal services are also possible. **Invalid URL: Medium, 50.** The destination cannot be classified, so review is our fail-safe input policy. URL checks are local parsing only.

Earlier non-allowed request of another type: Low, 25. Generic history is a weak cue. **Same name across those requests: Medium, 50.** A linked identifier is stronger than timing alone. Research [5] and monitoring guidance [6] motivate inspecting context, but our 25-to-50 uplift is a project hypothesis, not a published measured detection gain.

Age and downloads: zero points. We found no transferable support for universal 7-day or 50-download cutoffs in the reviewed papers. These remain visible information for the reviewer. This does not mean a trained ecosystem-specific model could never use them.

Avoid counting related evidence repeatedly

There are five groups: Identity & provenance; Requested capabilities; Static content; URL & transport; Session context. Only the strongest signal in each group contributes. All other reasons remain visible, labelled already covered. Equal-strength ties use the first detected signal.

group contribution = maximum base points within that group

score = min(100, sum of the five group contributions)

Grouping is a transparent MOSAIC design rule. It reduces repeated penalties for related cues and does not assume statistical independence between groups. It differs from Scorecard's original weighted-average formula.

Why the default boundaries are 50 and 75

Review starts at 50: one Medium concern, or two Low concerns from different groups. **Deny starts at 75:** one High concern, or a combination reaching the same intervention priority. Scores 0-49 Allow; 50-74 Needs review; 75-100 Deny.

These are policy choices aligned with the severity levels, not measured optimal thresholds. Changing them changes the tolerance for risk. A result of 100 can be a capped combination of concerns; it is not proof of a confirmed Critical threat.

Versioning: new receipts include severity-v2 and the policy used. Older saved records keep their original scores and hashes. Open a fresh replay to show this method. The 20-event history limit is a bounded implementation choice, not a research-derived coefficient.

4. Demonstration and answers for the panel

Verified demonstration values

Known publisher install: no configured concern matches; score **0, Allow**. This is not independent certification of safety.

New evaluation / Young integration: unknown existence 25 and unsigned 25 share the provenance group, so take 25. Network capability contributes 25. Age 6 and downloads 18 add nothing. **25 + 25 = 50, Needs review**.

Linked trust signals: first URL: missing 75, transport max(non-HTTPS 50, private host 50) = 50, capability 25. Total 150 is capped to **100, Deny**. Later skill: unsigned provenance 25, context max(previous activity 25, same name 50) = 50. **25 + 50 = 75, Deny**. Disable correlation, save and replay: skill becomes **25, Allow**. Restore correlation afterwards.

Over-privileged unknown source: missing 75 plus sensitive capability 50, capped to **100, Deny**. Its text is not recognised as an instruction override by the current narrow pattern; the explanation must follow the actual matched signals.

Suggested 40-second explanation

"We replaced individually chosen points with a severity-weight scale described in peer-reviewed IEEE research: 2.5, 5, 7.5 and 10. We multiply by ten for a 0-100 display. Security conference papers motivate hallucination, typosquatting, suspicious code and prompt-injection signals. We document our category assignments, group related evidence, and hold Medium concerns for review. The MVP demonstrates a reproducible method. We will calibrate the classifications and policy on labelled examples before claiming detection accuracy."

Likely questions

Did the paper measure those weights for your tool? No. We adopt its severity scale; the agent-request interpretation is our adaptation. That distinction is stated in the UI and documentation.

Why 75 rather than 48 for missing? High has the published weight 7.5, giving 75 in our units. We classify an explicit unavailable-artifact report as High-priority intervention. The paper motivates the scale; the conservative class assignment is our policy judgement.

Why not train a classifier? Labelled benign/malicious workflows and reliable independent evidence are not yet available in the MVP. An interpretable rubric is reproducible and exposes assumptions for review. Future learning must use a separate test set.

What does the test suite prove? Arithmetic, controls, persistence, grouping and version compatibility. It does not prove a detection rate. **How will you validate later?** Expert-reviewed labels, benign controls, a separate test set, detection/false-positive rates, correlation on/off ablation, threshold sensitivity and baseline comparisons.

5. References to cite

Peer-reviewed IEEE article supplying the scale

[1] N. Zahan, P. Kanakiya, B. Hambleton, S. Shohan, L. Williams, "OpenSSF Scorecard: On the Path Toward Ecosystem-Wide Automated Security Metrics," IEEE Security & Privacy, vol. 21, no. 6, pp. 76-88, 2023. DOI: **10.1109/MSEC.2023.3279773**. Weight locations: Section II and Table I of author manuscript. <https://arxiv.org/html/2208.03412v3#S2>

Security conference research motivating signals

[2] J. Spracklen et al., "We Have a Package for You! A Comprehensive Analysis of Package Hallucinations by Code Generating LLMs," 34th USENIX Security Symposium, 2025. Supports the hallucination attack surface, not our missing/unknown coefficients.
<https://www.usenix.org/conference/usenixsecurity25/presentation/spracklen>

[3] M. Ohm, H. Plate, A. Sykosch, M. Meier, "Backstabber's Knife Collection: A Review of Open Source Software Supply Chain Attacks," DIMVA, pp. 23-43, 2020. DOI: **10.1007/978-3-030-52683-2_2**. Supports typosquatting and execution/payload concerns. <https://arxiv.org/abs/2005.09535>

[4] A. Sejfia, M. Schafer, "Practical Automated Detection of Malicious npm Packages," 44th ACM/IEEE International Conference on Software Engineering, pp. 1681-1692, 2022. DOI: **10.1145/3510003.3510104**. Supports inspecting multiple indicators and validating detectors on labelled examples; its classifiers are not implemented here. <https://arxiv.org/abs/2202.13953>

[5] S. Abdelnabi, K. Greshake, S. Mishra, C. Endres, T. Holz, M. Fritz, "Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection," 16th ACM Workshop on Artificial Intelligence and Security, pp. 79-90, 2023. DOI: **10.1145/3605764.3623985**. Supports the indirect-injection threat. <https://arxiv.org/abs/2302.12173>

Additional engineering guidance (not research papers)

[6] OWASP AI Agent Security Cheat Sheet: least privilege and behavior monitoring.
https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html

[7] OWASP SSRF Prevention Cheat Sheet: destination validation and private-network boundaries. https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

[8] MITRE CWE-319: Cleartext Transmission of Sensitive Information.
<https://cwe.mitre.org/data/definitions/319.html>

Sources inspected 5 October 2026. A citation is evidence for the stated method or concern, not endorsement of MOSAIC. Complete rules: docs/SCORING.md. Implementation: shared/scoring.ts and server/engine.ts.